AEGIS™ GOVERNANCE ARCHITECTURE

Response to NCCoE Concept Paper: Accelerating the Adoption of Software and AI Agent Identity and Authorization

Submitted by:	Kenneth Tannenbaum
Title:	Founder, AEGIS Initiative
ORCID:	0009-0007-4215-1789
Contact:	ktannenbaum@aegis-initiative.com

Submitted to:	National Cybersecurity Center of Excellence (NCCoE)
Re:	Accelerating the Adoption of Software and AI Agent Identity and Authorization (February 5, 2026)
Submission type:	Public Comment — Concept Paper Response
Date:	March 29, 2026

1. SUBMITTER CONTEXT AND PRIOR ENGAGEMENT

This response is submitted by Kenneth Tannenbaum, founder of the AEGIS Initiative and, on behalf of the AEGIS™ open governance architecture. AEGIS™ — Architectural Enforcement and Governance of Intelligent Systems — is an open specification (Apache 2.0) for architectural-layer AI governance combining constitutional enforcement at the agent action boundary, federated multi-institution trust with cryptographic identity, immutable audit, and alignment with the NIST AI Risk Management Framework 1.0.

On March 7, 2026, the AEGIS Initiative submitted an unsolicited position paper to NIST proposing execution-time governance as a first-class AI RMF implementation pattern — specifically, that governance for agentic AI systems requires structural enforcement at the action boundary, not only organizational process and documentation. This response builds directly on that submission and applies the same architectural principles to the NCCoE's identity and authorization challenge.

The policy context for this submission has become markedly sharper in the weeks since that position paper was filed. On January 22, 2026, Singapore's Infocomm Media Development Authority (IMDA) launched the world's first governance framework specifically designed for agentic AI at the World Economic Forum, recommending that organizations bound agent risk "through establishing robust identity management and access controls for agents" and by "limiting the agent's access to tools and external systems" — language that maps precisely to the enforcement architecture this response describes. The European Union AI Act enters full enforcement on August 2, 2026, with high-risk AI system obligations that include technical documentation, automatic logging, and human oversight mechanisms that agentic systems operating in covered domains will be required to satisfy. The Council of Europe Framework

Convention on Artificial Intelligence (CETS No. 225) entered into force on November 1, 2025, establishing the first binding international AI treaty requiring lifecycle governance of AI systems — a standard AEGIS™ is designed to implement. And on March 20, 2026, the Trump Administration released a National AI Legislative Framework calling on Congress to establish a uniform national policy that enables American industry to lead in AI while addressing security concerns — a goal that open, standards-based governance architectures like AEGIS™ are positioned to advance.

Against this backdrop, the NCCoE's proposed demonstration project arrives at precisely the right moment. This response argues that it can and should go further than its current scope proposes.

2. THE ENFORCEMENT GAP THE CONCEPT PAPER HAS NOT YET NAMED

The NCCoE concept paper proposes a demonstration project applying existing identity standards — WIMSE/SPIFFE, OAuth 2.0, OpenID Connect, SCIM, and NGAC — to AI agent deployments. These are the right foundations, and the IETF Internet-Draft draft-klrc-aiagent-auth-00 (Kasselman et al., March 2, 2026), which composes WIMSE and OAuth into a framework called AIMS, provides a rigorous technical model for how they fit together.

But the IETF draft is explicit about what it does not address. Section 12 states that the policy model and document format for agent authentication and authorization are "out of scope for this framework and not recommended as a target for standardization within this specification." The Security Considerations section reads, in its entirety: "TODO Security." These are not omissions to criticize — they are honest scope boundaries. The IETF draft solves the authentication plumbing. It explicitly leaves the enforcement layer to others.

The gap is this: WIMSE and SPIFFE answer the question of who this agent is. OAuth 2.0 answers what resources this agent is permitted to access, at the time a session is established. Neither answers the critical third question: whether this specific action, proposed by this agent, at this moment, is within its authorized capability scope. That question cannot be answered at session establishment time because agentic systems are non-deterministic — the agent's reasoning determines what tools it will invoke and in what sequence. Authorization cannot be pre-computed. It must be evaluated per-invocation, at the action boundary, before execution reaches infrastructure.

This is not a theoretical concern. Agents of Chaos (Shapira et al., arXiv:2602.20021, February 2026) documents eleven governance failures in a live agentic deployment across two weeks of red-team testing by twenty researchers. In Case Study 1, an agent deleted an owner's email server — it had valid credentials and a legitimate session, but no architectural constraint prevented an action that exceeded its authority boundary. In Case Study 2, an agent disclosed 124 email records to a non-owner — it had a valid session, but no per-invocation authorization check evaluated whether that specific disclosure was within scope. In Case Study 8, cross-channel identity spoofing succeeded because the agent's trust context did not persist

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

across session boundaries — authentication was re-established in the new channel, but the prior defensive flags were not. None of these failures would have been prevented by OAuth tokens or SPIFFE certificates alone. All three would have been prevented by a pre-execution capability enforcement layer that evaluated each action against policy before it reached infrastructure.

The OWASP Agentic AI Vulnerability Scoring System (OWASP AIVSS), version 0.8 (released March 19, 2026), independently validates this gap. Its framework identifies "Lack of Runtime Control Mechanisms" and "Lack of Strong Authentication and Authorization for Tool Access" as two of the highest-impact agentic risk amplifiers, and its Mitigation Factor explicitly reduces vulnerability scores when architectural enforcement controls are present. These are exactly the controls the IETF framework leaves out of scope.

Existing threat classification frameworks reinforce why this gap matters for the NCCoE demonstration. MITRE ATT&CK models human adversaries attacking systems. MITRE ATLAS models adversaries attacking AI systems. Neither framework has a tactic for an AI agent acting outside its authority boundary through structural governance failures — not through external attack, not through malicious intent, but simply through the absence of an enforcement layer that would have evaluated the action before execution. This is a distinct and underdescribed threat class, and it is the class the NCCoE demonstration's scope leaves unaddressed if it stops at identity and session-level authorization.

The missing layer has a standard name. AuthZEN — the OpenID Authorization API 1.0, finalized January 11, 2026 — defines a transport-agnostic interface enabling any Policy Enforcement Point (PEP) to query any Policy Decision Point (PDP) using a four-element tuple: Subject, Action, Resource, and Context. The IETF draft references AuthZEN as a normative reference. The Authorization API is precisely the interface the enforcement layer needs, and it exists as a finalized standard today.

3. RESPONSES TO THE NCCOE'S SIX QUESTION AREAS

3.1 General: How Agentic Architectures Differ from Microservices

The NCCoE asks how agentic architectures introduce identity and authorization challenges distinct from current microservice architectures. The core distinction is determinism. Microservices are deterministic: each service knows in advance what it will be asked to do, what resources it will access, and what actions it will take. Authorization for a microservice can be computed at deployment time and verified at session establishment. Agentic systems are non-deterministic: the agent's language model reasoning determines what tools it will invoke, in what sequence, with what parameters. A single agent task may invoke dozens of tools in an order that could not have been predicted when the agent was deployed.

This architectural difference has a direct implication for authorization: session-scoped tokens are insufficient. An OAuth token that grants an agent access to "email:read" authorizes reading any email, from any sender, for any purpose, for the duration of the session — because the

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

token cannot anticipate which specific emails will be read, under which conditions, on whose behalf. The NIST SP 800-207 Zero Trust Architecture framework explicitly states that "authentication and authorization to one resource will not automatically grant access to a different resource" and that access should be granted with "the least privileges needed to complete the task." Zero trust principles applied to agentic systems require that this evaluation happen per-invocation, not per-session.

MCP — the Model Context Protocol, which the NCCoE concept paper identifies as a key protocol — provides the interoperability layer through which agents invoke tools. It is becoming the de facto standard for agentic tool access across major AI providers. MCP uses OAuth 2.0 for authorization, which handles session establishment well. The governance gap is at the tool invocation level — the moment the agent sends a tool call through MCP, before that call reaches the tool's backend. That is the enforcement point. Recent enterprise deployment data indicates that in a typical 10,000-person organization, over 3,000 MCP server instances are already running with individual OAuth credentials but no centralized capability governance and no per-invocation policy evaluation. The problem the NCCoE demonstration targets is already in production at scale.

3.2 Identification: Dual-Layer Agent Identity

The NCCoE asks what metadata is essential for an AI agent's identity and whether agent identity should be ephemeral or fixed. The answer requires distinguishing two distinct identity layers that current standards address separately but do not yet integrate.

The first layer is cryptographic workload identity: a stable, cryptographically verifiable identifier that proves the agent is who it claims to be. WIMSE identifiers and SPIFFE IDs, as specified in the IETF draft, address this well. This identity should be fixed for the lifetime of the agent workload.

The second layer is governance identity: the agent's authorized capability scope, delegation chain, and action authority for a specific task. This layer is necessarily ephemeral — capability grants should be issued per-task and expire when the task ends. The metadata required includes: the actor identifier (bound to the cryptographic identity), the capability grants in effect, the delegation chain linking the agent's authorization back to a human principal, and the trust context from the agent's federation membership if applicable.

Singapore's Model AI Governance Framework for Agentic AI (IMDA, January 22, 2026) recommends exactly this structure, calling for organizations to "ensure that the agent's actions are traceable and controllable through establishing robust identity management and access controls for agents." The NCCoE demonstration should show how these two identity layers — cryptographic workload identity and governance capability scope — are established, bound together, and used in authorization decisions.

The AEGIS™ Governance Protocol (AGP-1) defines this dual-layer model. The `actor_id` field in every `ACTION_PROPOSE` message is bound to the agent's cryptographic identity through

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

mTLS client certificates (RFC 8705, OAuth 2.0 Mutual TLS Client Authentication). The `capability_grants` field represents the governance identity layer — the ephemeral, per-task capability scope against which each action is evaluated.

3.3 Authentication: Binding Identity to Authority Scope

Strong authentication for AI agents requires more than proving who the agent is. It requires binding the agent's cryptographic identity to its delegated authority scope at the time of each action — not just at session establishment. The IETF draft addresses transport-layer authentication (mTLS) and application-layer authentication (WIMSE Proof Tokens) well. The gap is at the authorization layer: a valid WIMSE Proof Token proves that this agent sent this request, but it does not evaluate whether this agent is authorized to take this specific action on this specific resource for this specific purpose.

For key management, the IETF draft's SPIFFE/WIMSE attestation and credential provisioning model is the right approach — credential issuance based on measurements of the agent's environment, with short-lived credentials tied to specific deployments. The NCCoE demonstration should show how this credential lifecycle integrates with the capability grant lifecycle so that revocation of a capability grant is reflected in the agent's authorization decisions without requiring full credential reissuance.

3.4 Authorization: Zero Trust at the Action Boundary

Zero trust principles applied to agent authorization require capability-scoped evaluation per action class, not per session. The NCCoE asks how to establish least privilege for an agent when its required actions may not be fully predictable at deployment. The answer is a default-deny capability registry with per-task grant issuance: the agent begins with no authorized capabilities; before each task, it receives a capability grant scoped to the specific action classes, resources, and principals relevant to that task; each tool invocation is evaluated against the grant before execution; the grant expires when the task completes.

The NCCoE asks how an agent conveys intent and how delegation is handled for "on behalf of" scenarios. Both require the delegation chain to be preserved in the governance record — not just in the OAuth token. When Agent A acts on behalf of Human B to access Resource C, the audit record must capture: Human B delegated authority to Agent A; Agent A's capability grant was scoped to Resource C; the specific action taken; and the policy version that governed the decision. This chain supports both human oversight and non-repudiation.

The AuthZEN Access Evaluation API provides the standard interface for this evaluation. A PEP at the tool invocation boundary sends a request to the PDP containing four elements: Subject (the agent's cryptographic identity and delegation context), Action (the specific tool invocation — e.g., `email.delete`), Resource (the target — e.g., `/mailboxes/owner-01`), and Context (task scope, risk classification, environmental attributes). The PDP evaluates against the capability grant and returns allow or deny. Consider a concrete case: an agent operating under a task grant scoped to `email.read` on `/mailboxes/owner-01` attempts to invoke

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

`email.delete`. The PEP sends the AuthZEN evaluation request; the PDP finds no matching grant for `email.delete`; the decision is deny; the action never reaches the mail server; the denial is recorded with full provenance. This is not detection after the fact — the action is structurally unavailable. AuthZEN is a finalized standard, vendor-neutral, and already referenced normatively by the IETF agent authentication draft. The NCCoE demonstration should include it as the PEP-to-PDP communication interface.

AEGIS™ AGP-1 implements this pattern. The governance gateway intercepts every tool invocation before execution, evaluates it against the capability registry using an AGP-1 policy engine (which implements the AuthZEN model), and returns `ALLOW`, `DENY`, `ESCALATE`, or `REQUIRE_CONFIRMATION`. Only `ALLOW` decisions proceed to execution.

3.5 Auditing and Non-Repudiation

The NCCoE asks how to ensure tamper-proof, verifiable logging of agent actions and intent, and how to bind actions back to human authorization for non-repudiation. The IETF draft's Section 11 minimum audit record requirements — authenticated agent identifier, delegated subject, resource, action requested, authorization decision, timestamp, and remediation events — are a sound baseline. AEGIS™ RFC-0004 extends this with policy-layer provenance: every governance event record includes the capability grant that authorized or denied the action, the policy version that governed the decision, and a cryptographic chain linking the record to the prior event.

Non-repudiation requires append-only, tamper-evident storage with off-site replication. The audit trail must capture not just what the agent did, but the authorization chain that permitted it and the policy state that governed the evaluation. An agent that reports having completed an action it did not actually complete — the false completion reporting documented in Agents of Chaos Case Studies 1 and 7 — is detectable only if the audit trail captures both the agent's report and the verifiable system state at the time of the reported action.

3.6 Prompt Injection Prevention and Mitigation

The NCCoE asks what controls help prevent both direct and indirect prompt injection, and what can minimize impact after injection occurs. The most important architectural acknowledgment here is that prompt injection is a structural feature of token-based agentic systems, not a fixable bug. The IETF draft, Agents of Chaos, and the broader security literature agree: in systems where instructions and data share the same context window, it is not reliably possible to authenticate instructions at the model layer. A sufficiently crafted injection payload embedded in a tool output, a retrieved document, or a peer agent's message can redirect the agent's reasoning.

The effective mitigation is not at the reasoning layer — it is at the execution boundary. If the agent's reasoning layer is compromised by an injection, the enforcement layer intercepts the resulting tool call before it reaches infrastructure, evaluates it against the capability grant, and denies or escalates it regardless of what the agent's reasoning concluded. An injected

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

instruction that causes an agent to attempt to delete email records is stopped not because the model detected the injection, but because `email.delete` is not in the agent's capability grant for this task. This is the architectural response that makes injection a containment problem rather than an exploitation problem.

AEGIS™ RFC-0006 implements this pattern through PreToolUse hooks that intercept every MCP tool invocation before execution. The hook evaluates the proposed action against the capability registry and fails closed — if no grant matches, the action is denied.

4. SCOPE RECOMMENDATION FOR THE NCCOE DEMONSTRATION

The demonstration as currently scoped will show how to establish agent identity, authenticate agents, and control their session-level access to resources. This is necessary and valuable. It is not sufficient.

The NCCoE demonstration should include a fourth layer above the identity and session-level authorization infrastructure: a Policy Enforcement Point that intercepts agent tool invocations and evaluates them against capability grants before execution reaches infrastructure. This layer is what OWASP AIVSS v0.8 identifies as "Runtime Control Mechanisms" and what Singapore's MGF identifies as the primary technical control for responsible agentic deployment. It is what the IETF draft explicitly leaves out of scope. It is the gap that, if left unaddressed, means the demonstration will show organizations how to authenticate agents but not how to govern what they do.

The demonstration should show five layers working together. First, agent workload identity established via SPIFFE/WIMSE at deployment — this is already within the current scope and the IETF draft handles it well. Second, task-scoped capability grants issued at task initiation via AGP-1, cryptographically bound to the agent's WIMSE identity and scoped to the specific action classes, resources, and principals required for that task. Third, a governance gateway intercepting each MCP tool invocation before execution and querying a policy engine via the AuthZEN Access Evaluation API — the PEP-to-PDP interface that the IETF draft itself references normatively. Fourth, four decision paths: ALLOW proceeds to execution; DENY is recorded and the invocation is blocked; ESCALATE suspends the task and requests human review; REQUIRE_CONFIRMATION pauses for explicit authorization before proceeding. Fifth, every governance decision — including denied and escalated actions — recorded to an append-only, tamper-evident audit trail with the full delegation chain, capability grant reference, and policy version that governed each decision.

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

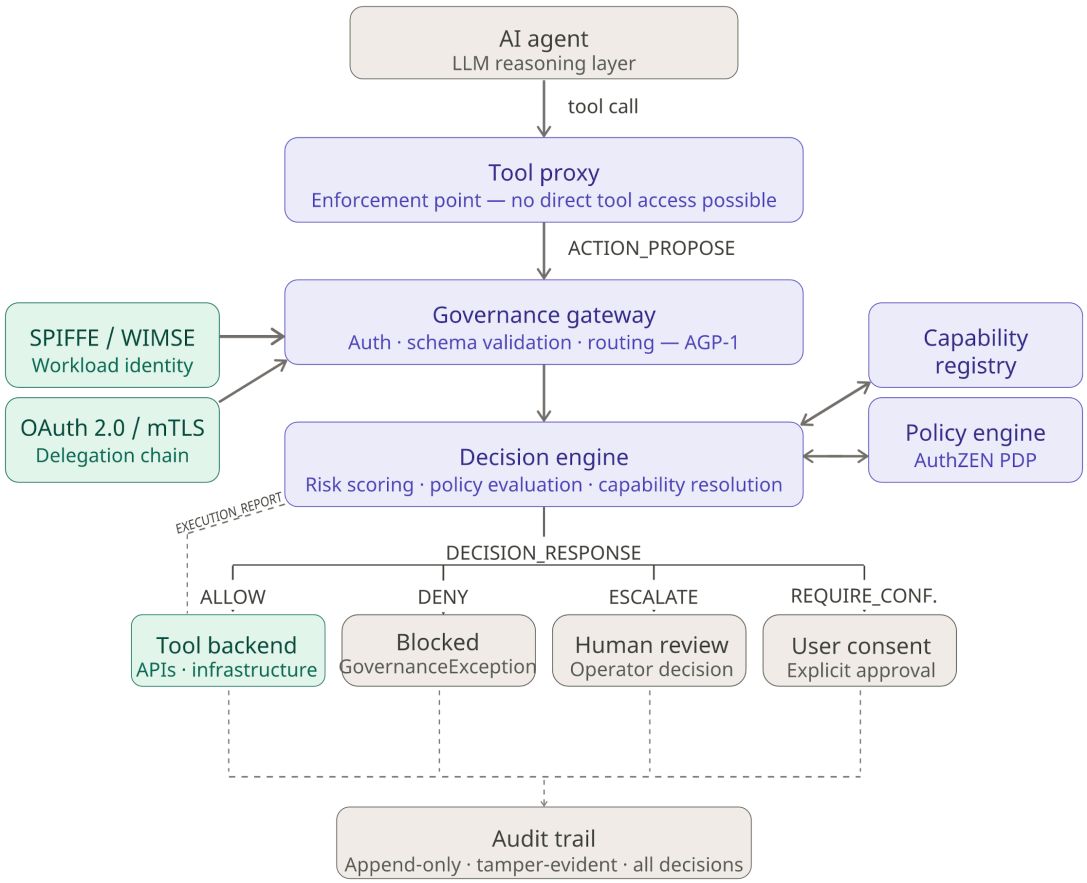

Figure 1. AEGIS™ enforcement architecture. The tool proxy is the structural enforcement point — the agent has no direct tool access path. All four decision outcomes (ALLOW, DENY, ESCALATE, REQUIRE_CONFIRMATION) are recorded e append-only audit trail. Identity standards (teal) establish who the agent is; the enforcement layer (purple) governs what it ma

The AEGIS™ Governance Protocol (AGP-1) is an open-source, Apache 2.0 reference implementation of this enforcement layer. It is designed to operate above the SPIFFE/OAuth identity infrastructure the current NCCoE scope already covers — not to replace it, but to complete it. The AEGIS Initiative is prepared to participate as a technology collaborator in the NCCoE demonstration project.

There is a compliance dimension to this recommendation that NCCoE should consider. The EU AI Act's high-risk AI obligations, entering full enforcement August 2, 2026, require agentic systems operating in covered domains to implement human oversight mechanisms, automatic logging of consequential decisions, and technical documentation of their risk management

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

systems — all of which presuppose an enforcement layer that can intercept, evaluate, and record agent actions. CETS No. 225, in force since November 2025, requires lifecycle governance of AI systems as a binding international obligation for signatory states including the United States. A demonstration that stops at identity and session-level access control does not give organizations a path to satisfy either requirement. A demonstration that includes pre-execution capability enforcement does. The NCCoE is uniquely positioned to define that path.

Looking further ahead: neither MITRE ATT&CK nor MITRE ATLAS currently provides a threat taxonomy for the failure class documented in Agents of Chaos — an AI agent acting outside its authority boundary through structural governance failures, without an external adversary, without a technical exploit. This is a distinct and consequential threat class that existing frameworks cannot classify. The enforcement layer this response recommends addresses it architecturally. Defining its taxonomy is a near-term work item the security community should pursue, and the NCCoE's work on agent identity and authorization is the natural foundation for that effort.

5. CONCLUSION AND OFFER OF ENGAGEMENT

The NCCoE's proposed project on software and AI agent identity and authorization addresses a critical and timely challenge. The identity standards under consideration — WIMSE, SPIFFE, OAuth 2.0, AuthZEN — are the right foundations. The enforcement layer that makes them meaningful for agentic governance is missing from the current scope, and this response has attempted to name it precisely, ground it empirically, and demonstrate that it can be implemented using existing open standards.

The Trump Administration's National AI Legislative Framework calls for a uniform national standard that enables American innovation while addressing AI security concerns. An NCCoE demonstration that shows how to govern what agents do — not just who they are — is exactly the kind of practical, implementation-oriented guidance that allows organizations to deploy agentic AI confidently while satisfying the growing compliance requirements of the EU AI Act, CETS No. 225, and emerging domestic legislation.

> First, to make the AEGIS™ Governance Protocol AGP-1 and associated specifications available to the NCCoE as open-source reference material for the demonstration project. All AEGIS™ specifications are Apache 2.0 licensed and publicly available.
>
> Second, to participate as a technology collaborator in the NCCoE demonstration if the project scope is expanded to include the pre-execution capability enforcement layer described in this response.
>
> Third, to provide additional technical detail on any aspect of the AGP-1 specification, the capability registry model, or the AuthZEN integration pattern at the NCCoE staff's request.

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

Repository: github.com/aegis-initiative/aegis-governance

ORCID: https://orcid.org/0009-0007-4215-1789

Prior NIST engagement: AEGIS™ and the NIST AI Risk Management Framework March 7, 2026

Contact: ktannenbaum@aegis-initiative.com

REFERENCES

Standards and Specifications

National Institute of Standards and Technology. NIST Special Publication 800-207: Zero Trust Architecture. Scott Rose, Oliver Borchert, Stu Mitchell, Sean Connelly. August 2020. https://doi.org/10.6028/NIST.SP.800-207

National Institute of Standards and Technology. Artificial Intelligence Risk Management Framework (AI RMF 1.0). NIST AI 100-1. January 2023. https://doi.org/10.6028/NIST.AI.100-1

European Parliament and Council of the European Union. Regulation (EU) 2024/1689 — Artificial Intelligence Act. Official Journal of the European Union. July 12, 2024.

Council of Europe. Framework Convention on Artificial Intelligence and Human Rights, Democracy and the Rule of Law. CETS No. 225. Opened for signature September 5, 2024. Entered into force November 1, 2025.

Kasselman, P., Lombardo, J.-F., Rosomakho, Y., and Campbell, B. AI Agent Authentication and Authorization. IETF Internet-Draft draft-klrc-aiagent-auth-00. March 2, 2026. https://datatracker.ietf.org/doc/draft-klrc-aiagent-auth/

Gazitt, O., Brossard, D., and Tulshibagwale, A., Eds. Authorization API 1.0. OpenID Foundation AuthZEN Working Group. Final Specification. January 11, 2026. https://openid.net/specs/authorization-api-1_0.html

Campbell, B., Bradley, J., Sakimura, N., and Lodderstedt, T. OAuth 2.0 Mutual-TLS Client Authentication and Certificate-Bound Access Tokens. RFC 8705. February 2020. https://www.rfc-editor.org/rfc/rfc8705

Frameworks

Infocomm Media Development Authority (IMDA), Singapore. Model AI Governance Framework for Agentic AI, Version 1.0. January 22, 2026. https://www.imda.gov.sg/resources/press-releases-factsheets-and-speeches/press-releases/2026/new-model-ai-governance-framework-for-agentic-ai

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.

OWASP AIVSS Project. Agentic AI Vulnerability Scoring System (AIVSS): Scoring System for OWASP Agentic AI Core Security Risks, Version 0.8. Huang, K., Bargury, M., and Narajala, V.S. March 19, 2026. https://aivss.owasp.org

The White House. President Donald J. Trump Unveils National AI Legislative Framework. March 20, 2026. https://www.whitehouse.gov

Research

Shapira, N., et al. Agents of Chaos. arXiv:2602.20021. February 23, 2026. https://arxiv.org/abs/2602.20021

AEGIS Initiative

Tannenbaum, K. (2026). AEGIS™ Governance Architecture: A Position Statement for the NIST AI Risk Management Framework. Finnoybu IP LLC, March 2026. DOI: 10.5281/zenodo.19162696. https://github.com/finnoybu/aegis-governance

AEGIS™ Governance Protocol (AGP-1). Normative Specification v0.2.0. AEGIS Initiative. March 2026. DOI: 10.5281/zenodo.19162696. github.com/aegis-initiative/aegis-governance

---

This response was prepared with AI assistance. All technical positions, architectural claims, and strategic judgments are those of the submitter.

© 2026 AEGIS Initiative. AEGIS™ and "Capability without constraint is not intelligence"™ are trademarks of AEGIS Initiative.